RELATÓRIO TÉCNICO DE PENTEST

Support Operations Platform | TryHackMe — avaliação web, escalada de privilégios e execução de comandos

Campo	Informação
Alvo	10.64.160.114 (instância do laboratório)
Evidências técnicas	16 de outubro de 2026
Escopo	CTF / ambiente autorizado TryHackMe
Stack identificada	Apache 2.4.58, PHP 8.3.6, OpenSSH 9.6p1 (Ubuntu)
Resultado	Acesso administrativo, RCE e leitura da segunda flag concluídos
Registro da flag	Valor literal não fornecido para inclusão no documento

1. Resumo executivo

A investigação demonstrou uma cadeia de comprometimento que começou com acesso de helpdesk, passou por divulgação de código-fonte e dados de usuários, permitiu identificar uma credencial administrativa derivada de segredo exposto e culminou em execução remota de comandos no host como www-data. O operador confirmou posteriormente que conseguiu ler a segunda flag do laboratório.

A execução de date;id foi observada na resposta HTTP do servidor. A leitura da segunda flag é registrada como concluída conforme confirmação do operador; o conteúdo literal da flag e a resposta HTTP correspondente não foram disponibilizados para anexação. Não se afirma obtenção de shell interativa nem privilégio root.

2. Escopo e metodologia

Foram utilizados reconhecimento HTTP/SSH, enumeração de diretórios, inspeção de PHP divulgado, análise de autenticação/sessão, verificação de controle de acesso por objeto, teste de credencial administrativa e exploração controlada de injeção de comandos. A avaliação é restrita à instância do CTF.

3. Linha do tempo da exploração

Fase	Evidência / resultado
Reconhecimento	Portas TCP 22 (SSH) e 80 (HTTP); Apache e PHP identificados.
Acesso inicial	Credencial helpdesk: help@support.thm / snoopy.
Código-fonte	Leitura de arquivos PHP do webroot pelo parâmetro skin.
API / autorização	Consulta indevida a perfil administrativo e falsificação do cookie isITUser.

Fase	Evidência / resultado
Autenticação administrativa	specialadmin@support.thm autenticou com support110, derivada de support@110.
RCE	POST /api.php com sys=date%3Bid retornou uid=33(www-data).
Objetivo final	Operador confirmou leitura de /home/ubuntu/user.txt.

4. Achados técnicos confirmados

F-01 | Divulgação de código-fonte por skin — Alta

O dashboard resolve um tema com realpath() e entrega o arquivo via readfile(), mas valida a permanência dentro de /var/www/html, e não exclusivamente em /skins. Um usuário autenticado pôde ler PHP de componentes internos. A leitura de /var/www/db.php, fora do webroot, não foi demonstrada.

```
GET /dashboard.php?skin=../config
GET /dashboard.php?skin=../index
GET /dashboard.php?skin=../api
```

F-02 | Exposição de segredo e senha administrativa previsível — Crítica em cadeia

O config.php expôs MASTER_PASSWORD = support@110. O valor literal não autenticou, mas sua mutação simples support110 foi validada como senha de specialadmin@support.thm. O código recuperado não demonstra uso direto da variável MASTER_PASSWORD pelo login: trata-se de descoberta de credencial relacionada, não de bypass por senha mestre.

F-03 | IDOR / BOLA na API — Média

A API recebe id do cliente e consulta usuários sem impor correspondência com a identidade da sessão. A rota /user/1 expôs email, 2FA e admin do administrador. /user/1 e /api.php?id=1 são duas formas de acionar a mesma lógica; nenhuma alteração de registro foi comprovada.

```
GET /user/1
{"email":"specialadmin@support.thm","2FA":false,"admin":true}
```

F-04 | Confiança em cookie controlado pelo cliente — Média

O cookie isITUser, calculado como MD5 estático de true/false, pôde ser falsificado para exibir funcionalidades de IT e consultar a API a partir de uma sessão helpdesk. Isso não modificou $_SESSION[admin] no servidor.

```
isITUser=b326b5062b2f0e69046810717534cb09
```

F-05 | Command Injection autenticada — Crítica

Em footer.php, shell_exec($sys) é chamado quando strpos($sys, "date") === 0. A validação por prefixo permite encadear comandos com ponto e vírgula. Com sessão administrativa, o POST em /api.php comprovou execução de comandos no sistema operacional.

```
POST /api.php
Content-Type: application/x-www-form-urlencoded

sys=date%3Bid

Fri Oct 16 20:49:11 UTC 2026
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

5. Testes negativos e limitações

Teste	Resultado
SSH	Autenticação publickey para usuário testado; nenhuma chave disponível.
Traversal HTTP /../db.php	400 Bad Request.
Configuração Apache	/.htaccess, /.htpasswd e /server-status: 403; /server-info: 404.
Diretórios listáveis	/includes, /js e /layout; arquivos conhecidos e bibliotecas Bootstrap.
Arquivos PHP candidatos	16 caminhos auxiliares testados via skin, sem código novo.
Sessão PHP	Nos arquivos recuperados, somente o login atribui $_SESSION[admin].

6. Cadeia de exploração

Helpdesk → leitura de PHP → segredo exposto + identificação do administrador → mutação de senha → login admin → Command Injection → execução como www-data → leitura da flag user (confirmada pelo operador).

A flag web é exposta pelo dashboard quando $_SESSION[admin] é true. O login administrativo foi confirmado; o valor literal de /var/www/web.txt não foi compartilhado para transcrição no relatório.

7. Recomendações prioritárias

Prioridade	Correção
P0	Substituir shell_exec com entrada do usuário por operações fixas e APIs nativas.
P0	Revogar e substituir credenciais; retirar segredos do código acessível e aplicar cofre de segredos.
P1	Usar allowlist estrita de temas; impedir leitura de PHP fora de /skins.
P1	Implementar autorização por objeto na API, com vínculo ao usuário autenticado.
P1	Não tomar decisões de autorização com cookies controláveis pelo cliente.
P2	Remover phpinfo e directory listing em produção; reforçar logs e testes.

8. Evidências e estado final das flags

Flag web: acesso administrativo comprovado; o dashboard contém rotina para exibir /var/www/web.txt. Valor literal não registrado neste documento.

Flag user: leitura de /home/ubuntu/user.txt confirmada pelo operador após a exploração. A saída exata do comando de leitura e o valor literal da flag não foram enviados; portanto, não são reproduzidos ou inventados.

Evidências diretamente observadas: código PHP recuperado, perfil JSON de administrador, autenticação administrativa confirmada pelo operador, requisição POST sys=date%3Bid e resposta com uid=33(www-data).

9. Conclusão

O laboratório foi concluído segundo a confirmação do operador, com exploração web e leitura da segunda flag. A evidência técnica anexada comprova de forma independente a execução de comandos como www-data. O caso ilustra como uma cadeia de divulgação de informações, credencial previsível e falha de validação de comandos pode produzir comprometimento de alto impacto.